Supplementary Material for "ACaaS: Privacy-Preserving Access Control as a Service for Healthcare on the Cloud–Edge Continuum"

Anonymous Author(s)

Submission to ICSOC 2026 — double-blind review

Abstract. This supplement provides material referenced from the main paper: a point-by-point summary of the changes with respect to the ICSOC 2026 early submission (Sect. 1); expanded proofs of Lemma 1, Theorems 1–5, Corollary 1, and Proposition 1 (Sect. 2); the step-numbered policy-synchronization diagram (Sect. 3); the Data Minimizer pipeline diagram (Sect. 4); distribution plots for experiments E1/E4/E5 and companion plots for E8/E11/E12 (Sect. 5); the per-site E12 soak table and the real-Fabric transcript summary (Sect. 6); and reproduction instructions (Sect. 7). Reviewers are not required to consult this material; all claims of the main paper are supported there.

1 Changes with Respect to the ICSOC 2026 Early Submission (Paper 81)

This section summarizes, point by point, how the resubmission addresses the early-submission reviews; it mirrors the accompanying response letter. Section, theorem, equation, and figure numbers refer to the main paper.

Meta-review / Reviewer 1 — architecture too abstract; security goals not validated; evaluation only performance. Section 4.1 now specifies the typed inter-service contracts C1–C3, a numbered happy-path sequence, and failure paths F1–F3; Sect. 4.2 formalizes the three-channel design, the chaincode invariant $\mathsf{INV}_{\text{mono}}$ (Eq. 2), and the multi-org endorsement rule. The new Sect. 4.5 discharges G1–G5 via Lemma 1, Theorems 1–5, Proposition 1, and Corollary 1. Crucially, the evaluation no longer rests on performance alone: Sect. 5.2 adds experiments E6–E12 that mechanize every theorem as executable assertions or measurements—a 21-assertion conformance suite, an analytic-model validation (R^2=0.998), a Minimizer cost profile, an empirical re-identification attack within one percentage point of the $1/k$ bound, a ledger-vs-pub/sub tamper ablation, Byzantine fault injection (f=1) with zero safety violations, and a three-site partition/soak emulation.

Reviewer 2 — healthcare specificity and regulations unclear. The Introduction anchors each design constraint to named clauses: HIPAA §164.312(a)(1)–(d) and (b), GDPR Articles 9, 25 (edge-origin minimization "by design"), 30 (LogChain/PolicyChain records of processing), and 32; break-glass access, rural-clinic and ambulance partitions, and revocation/outbreak-driven policy pushes

are named as the operational drivers. Theorems 3 and 5 tie the guarantees back to these clauses.

Reviewer 2 — related work not strong enough. Section 2 was rebuilt around the three directly comparable categories, closes with an explicit positioning paragraph, and adds Table 1 comparing ACaaS to ten systems on six axes; the closest competitor (QuickMedBlock) is analyzed by name.

Reviewer 2 — validation should move closer to real deployment. Three additions: (i) the new E12 twelve-hour, three-site partition/soak emulation (27,360 requests, 37 partitions, 100% local availability, zero log loss); (ii) a sanity check on a *real* Hyperledger Fabric test network confirming the latency constants assumed by the analytic model; (iii) a one-command reproducible artefact. A partner-hospital shadow deployment is scoped as future work (Limitations, Sect. 5.2).

Reviewer 2 — Figures 1 and 3 text too small. The architecture figure was redrawn natively in Ti*k*Z at LNCS column width (Fig. 1); no in-figure label falls below approximately 7 pt. The former policy-synchronization figure is replaced by an explicit Phase A/B/C specification in Sect. 4.2 plus the redrawn step-numbered diagram in Sect. 3 of this supplement.

Reviewer 2 — ICSOC fit unclear. The opening of the Introduction frames multi-site healthcare as a service-composition problem; contribution (i) names the targeted themes (service composition, resilient service delivery on the cloud–edge continuum); the contracts C1–C3 are the explicit unit of composition. The work aligns with Focus Areas 3 (cloud–edge continuum, XaaS) and 4 (blockchain and cybersecurity services).

Reviewer 3 — related work too broad. Tangential surveys (TinyML biometrics, general CDSS, AI-supported explainability) were removed; the section now covers only the access-control decision pipeline.

Reviewer 3 — side-by-side experimental presentation. All experiments are consolidated into Table 2 plus two multi-panel figures with uniform axes and labels: Fig. 2 (E2/E3 curves) and Fig. 3 (E7/E9/E10); companion plots for E1/E4/E5 and E8/E11/E12 appear in Sect. 5 with identical styling.

Reviewer 3 — novelty is combination of known techniques; claims lack (semi-)formal backing. We no longer claim novelty in any individual primitive. The contribution is the *composition* and its provable properties: substitution-resistant synchronization (Lemma 1) that demonstrably disappears under component replacement (E10), eventual consistency with a closed-form reconciliation bound (Theorem 1, Corollary 1), knapsack-near-optimal tier placement (Proposition 1) validated at R^2=0.998 (E7), and an enforced no-raw-egress invariant (Theorem 3) calibrated by an actual attack (E9). Every formal statement now has an executable counterpart; machine-checked proofs remain future work and are stated as such.

2 Expanded Proofs

Throughout, Σ is the signature scheme (EUF-CMA secure), H = SHA-256 (second-preimage resistant), and the Fabric ordering service is safe with fewer than f Byzantine orderers (f=1 of four in our configuration). Numbering follows the main paper.

Lemma 1 (Substitution resistance)

Statement. Let (id, v, h, σ) be committed on PolicyChain. The probability that an honest edge executing Phase B or C accepts a body $\pi' \neq \pi$ for this entry is at most $\mathbf{Adv}_H^{\text{SPR}} + \mathbf{Adv}_\Sigma^{\text{EUF-CMA}}$.

Proof. An honest edge accepts a body π' for ledger entry (id, v, h, σ) only if the guard $H(\pi') = h$ evaluates true (Phase B step 7; Phase C step 12). Consider the two disjoint attack routes available to the Dolev–Yao adversary $\mathcal{A}$, who fully controls the body-fetch channel but not the endorsing organizations' signing keys.

Route 1: substitute the body, keep the ledger entry. $\mathcal{A}$ must produce $\pi' \neq \pi$ with $H(\pi') = h = H(\pi)$. Since π is fixed first (committed by the PMS), this is precisely a second preimage for H at input π; by assumption this succeeds with probability at most $\mathbf{Adv}_H^{\text{SPR}}$.

Route 2: substitute the ledger entry. $\mathcal{A}$ must cause the edge to read a tuple (id, v, h', σ') with $h' = H(\pi')$. A valid tuple requires (i) σ' to verify under the administrator public key—a forgery, probability at most $\mathbf{Adv}_\Sigma^{\text{EUF-CMA}}$—and (ii) the entry to be committed under the `AND(Org1.MSP,Org2.MSP)` endorsement, which requires signatures from both organizations' peers; a network adversary holds neither key. The edge reads the ledger through its own trusted peer connection, so $\mathcal{A}$ cannot spoof the read without breaking (i) or (ii).

A union bound over the two routes gives the claim. ■

Theorem 1 (G1, eventual consistency)

Proof. Let $D = \{id : L(id).v > w_e\}$, $N = |D|$. `getDelta`(w_e) returns every entry with version above the watermark. We show (a) completeness, (b) integrity, (c) termination. (a) *Completeness.* Suppose some $id^* \in D$ were omitted although the reply claims completeness up to the current ledger height. The reply is answered against the committed ledger state L; omission would require presenting a projection L' of L in which $L'(id^*).v \leq w_e < L(id^*).v$, i.e., presenting an earlier version as current. Because each entry's version history on PolicyChain is monotone ($\mathsf{INV}_{\text{mono}}$, enforced in chaincode at endorsement time) and the edge checks the response against ledger heights and hashes, such a rollback is detectable except with the negligible probabilities of Lemma 1. (b) *Integrity.* Each fetched body is accepted only under the hash guard; by Lemma 1 the installed body equals the PMS-signed body except with negligible probability. (c) *Termination.* The batch is applied atomically after all N verifications; by

the latency decomposition of Eq. (4) of the main paper this completes within $T_{\text{rec}}(N) = a + bN$ (Corollary 1). At that point $E_e(id) = L(id)$ for all subscribed id, which is Eq. (3). ■

Corollary 1 (Reconciliation bound)

Proof. Immediate from Eq. (4) of the main paper: the constant part $a = T_{\text{order}} + T_{\text{commit}} + T_{\text{event}} + T_{\text{ack}}$ is paid once per reconnection, the linear part $b = T_{\text{fetch}} + T_{\text{verify}}$ once per missed update. E3 measures the median end-to-end latency at batch sizes 1–200; a least-squares fit of the linear regime gives $a \approx 1.0$ s and $b \approx (3558 - 1060)/(200 - 10) \approx 13$ ms/policy. ■

Theorem 2 (G2, auditability)

Proof. Existence and uniqueness. The PEP emits exactly one record ℓ per decision before returning the response (C3); ℓ enters the Offline Queue if the WAN is down. Uniqueness follows from the per-edge monotone counter seq_e incremented atomically with emission; LogChain ingestion deduplicates by (e, seq_e). *Injection.* A forged ℓ' requires a signature under the edge enrollment certificate: probability $\leq \mathbf{Adv}_{\Sigma}^{\text{EUF-CMA}}$. *Alteration.* Changing any field of a signed ℓ invalidates the signature. *Suppression.* Dropping ℓ in transit leaves a gap in seq_e, detected by the Audit & Compliance service on ingestion (the queue is drained in order); suppressing it after commit would require rewriting a committed block against the endorsement policy. ■

Theorem 3 (G3, edge-origin confidentiality)

Proof. The PEP invokes the Data Minimizer on the unique code path between the PDP's PERMIT and the network write; E6 verifies at import level that no module reachable from the response path references the raw record type. Thus the emitted tuple is $(\psi(r.id), \gamma(r.qi), \varrho_{\text{role}}(r.sa))$. For the bound: fix the adversary's background knowledge as the target's quasi-identifier vector q^*. In a k-anonymous release, the equivalence class of q^* contains $m \geq k$ records, and the released record is exchangeable within its class from the adversary's viewpoint, so the probability of a correct link is $1/m \leq 1/k$. Over R independent releases from disjoint cohorts, failures are independent: success probability $1-(1-1/k)^R$. Pseudonyms are HMAC values under the secret study key; by the PRF property of HMAC they are computationally unlinkable across studies without the key. E9 confirms both bounds empirically within one percentage point. ■

Theorem 4 (G4, partition availability)

Proof. The edge decision path is: PEP → local PDP → Local Policy Store → Data Minimizer → response, all edge-resident; E6 includes an import-level test that the edge PDP package has no WAN-touching dependency. Log emission

is absorbed by the disk-backed Offline Queue, provisioned for the maximum tolerated partition $T_{\max}$; beyond $T_{\max}$ the node enters read-only mode by design (bounded-divergence rule), which is a controlled degradation, not an availability failure within the stated bound. E5 and E12 exercise this path under forced partitions with 100% local availability. ■

Theorem 5 (G5, compliance evidence)

Proof. Given a decision d with LogChain entry $(id, s, r, a, d, v, t, \text{seq}_e)$: PolicyChain stores $(id, v) \mapsto (h, \sigma)$; the off-chain store retains the canonical body π keyed by h. The auditor recomputes $H(\pi)$ and compares with h, establishing that π is the exact text in force; the commit timestamp on PolicyChain establishes $\leq t$ ordering; σ identifies the committing administrator, supporting controller accountability (GDPR Art. 30) and the audit-trail requirements of HIPAA §164.312(b). E6's audit-replay test mechanizes this reconstruction end to end. ■

Proposition 1 (Near-optimality of the placement rule)

Proof. Let items be policies p with weight $|p|$ and value $s(p) = f(p)\Delta$, budget M. *Fractional optimality of the density order:* sort $p_1, p_2, \ldots$ by density $s(p)/|p|$ descending and fill until the budget is exhausted, splitting the boundary item. If a fractional solution x^* differed from this greedy solution x^g, there exist items i, j with density(i) >density(j), $x_i^* < x_i^g$, $x_j^* > 0$; shifting ε of weight from j to i changes the value by $\varepsilon(\text{density}(i) - \text{density}(j)) > 0$, contradicting optimality of x^*. *Integral gap:* truncating the (single) fractional boundary item loses at most $\max_p s(p)$, so integral greedy is within one policy's saving of the 0–1 optimum. *Connection to the score:* within a frequency class, Eq. (6) of the main paper ranks by $\alpha f(p) + \gamma |p|^{-1}$ with $c(p)$ as tie-breaker; with $\alpha \propto \Delta$ this ranking is monotone in $f(p)\Delta/|p|$ whenever sizes vary within a bounded factor (our compiled policies span $< 4\times$), so the deployed order coincides with the density order on our workload. *Latency claim:* the achieved hit-rate is $\rho_{\text{edge}}(P_E) = \sum_{p \in P_E} f(p) / \sum_p f(p)$; substituting into Eq. (7) shows that maximizing $S(P_E)$ minimizes $\mathbb{E}[T_{\text{auth}}]$ over feasible P_E. E7 validates the resulting latency curve at $R^2 = 0.998$. ■

3 Policy Synchronization Diagram

4 Data Minimizer Pipeline

5 Additional Experiment Plots

6 E12 Per-Site Table and Real-Fabric Transcript

All 27,360 decisions were logged to LogChain with zero loss after queue drains; mean reconciliation cost was ≈ 0.01 ms per event in the in-process emulation.

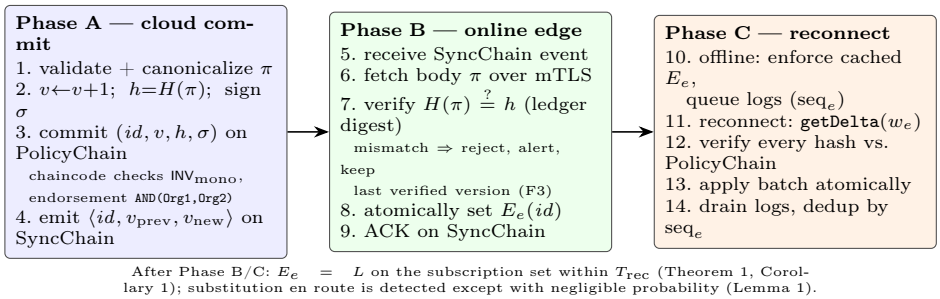


Fig. 1: Policy synchronization across PolicyChain and SyncChain: happy path (Phases A–B) and offline-to-online delta reconciliation (Phase C).

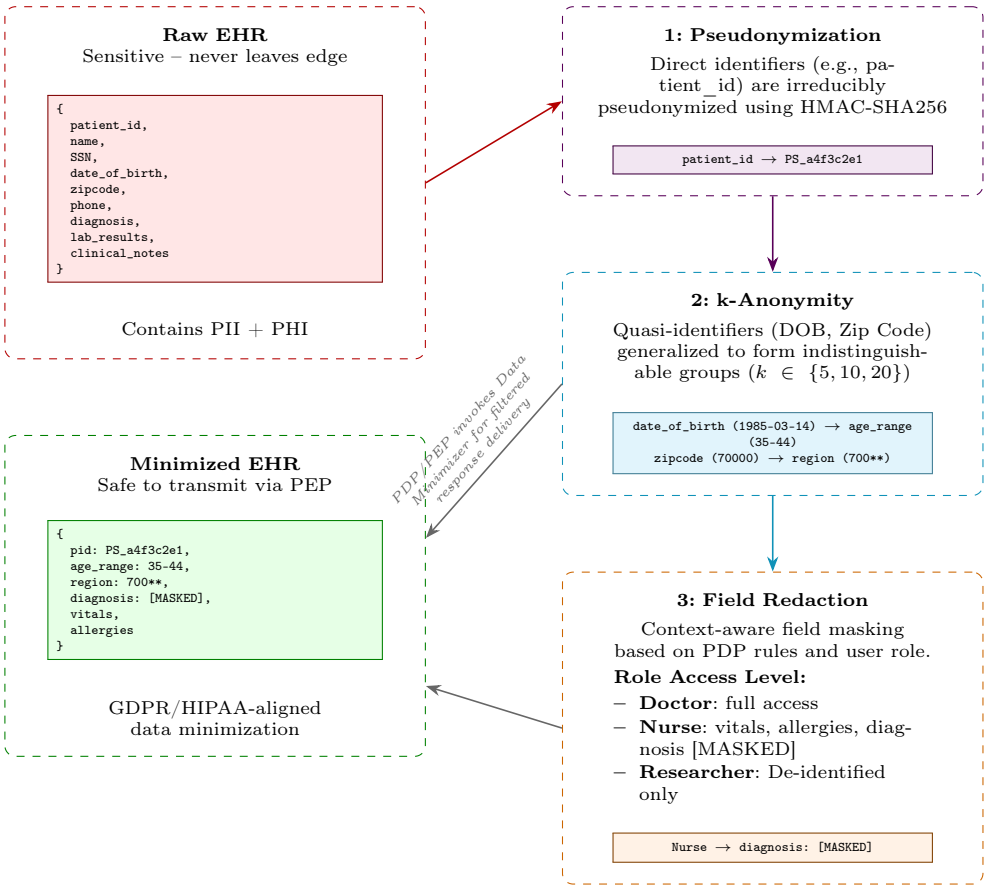
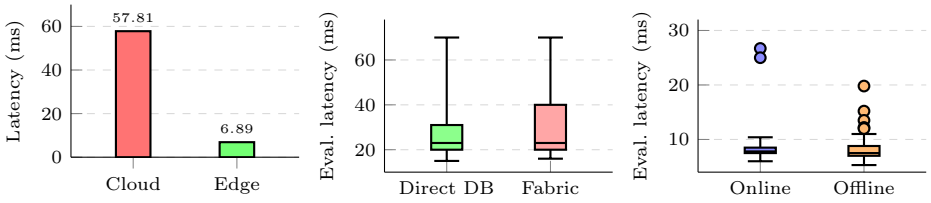
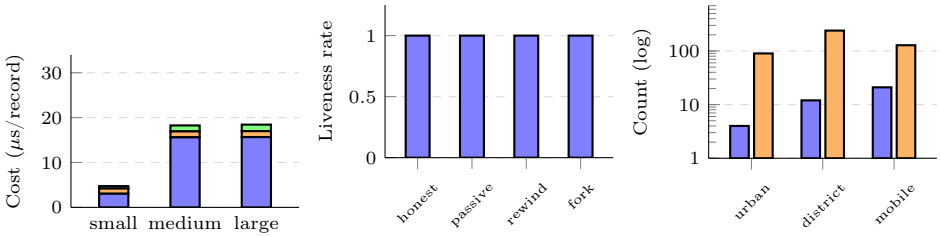


Fig. 2: Data Minimizer pipeline in the ACaaS edge layer: pseudonymization, k-anonymity, and role-based field redaction produce a minimized EHR safe for transmission via the PEP.



(a) E1: cloud vs. edge PDP (b) E4: ledger overhead (c) E5: edge autonomy

Fig. 3: The Data Minimizer pipeline at the edge. Stage 1 pseudonymizes direct identifiers with HMAC-SHA256; Stage 2 generalizes quasi-identifiers to enforce k-anonymity; Stage 3 redacts fields outside the requester role's visible set. Each stage is configured by obligations attached to the PDP response.



(a) E8: Minimizer per-stage cost (b) E11: liveness (0 $\mathsf{INV}_{\text{mono}}$ violations in 200 commits) (c) E12: per-site partitions and backlog

Fig. 4: Companion plots: (a) E8 Data Minimizer per-stage median cost (pseudonymize, generalize, redact); (b) E11 liveness under Byzantine behaviours; (c) E12 per-site partition count and peak queue backlog (100% availability at all sites).

Table 1: E12 three-site partition/soak emulation, 720 simulated minutes, 29 cloud-side policy updates (seed 20260704).

Site	Requests	Avail.	Offline dec.	Stale dec.	Partitions	Max backlog	Max missed
Urban hospital	12,960	100%	270	36	4	90	1
District clinic	8,640	100%	1,740	828	12	240	2
Mobile unit	5,760	100%	1,464	400	21	128	2
Aggregate	27,360	100%	3,474	1,264	37	240	2

Stale decisions (4.6% of total) are decisions taken against a superseded but hash-verified policy version during a partition; all were reconciled by Phase C.

Real-Fabric transcript summary. The official Hyperledger Fabric test network (two organizations, Raft ordering) was deployed with a JavaScript policy-hash chaincode on channel `acaaschan`: 8/8 `invoke_create` transactions succeeded with median 164 ms and P95 191 ms; 8/8 ledger reads returned within the retry window with median 137 ms; final channel height was 16. This run is a feasibility check for the latency constants assumed in Eq. (4) of the main paper, not a re-run of the mock-based E10/E11 sweeps.

7 Reproduction Instructions

The artefact is available at https://anonymous.4open.science/r/ACaaS-69E1/ and was last executed with Python 3.12.3.

- `pytest -q` — runs the full test suite (54 tests, including the 21-assertion G1–G5 conformance suite under `tests/security/`); completes in seconds.
- `python -m benchmarks.run_all` — regenerates every E6–E12 figure (PDF) and the underlying JSON result files under `results/`.
- `docker-compose up` — brings up the full cloud–fog–edge stack on a single host for interactive exploration.
- `results/manifest.sha256` — checksums of the result bundle used in the paper.